

GZ: 2023-0.046.014 dated January 30, 2023 (Case number: DSB-D084.4371)

[Note from the editor: Names and companies, legal forms and product designations, addresses (including URLs, IP and email addresses), file numbers (and the like), etc., as well as their initials and abbreviations may have been abbreviated and/or altered for pseudonymization reasons. Obvious spelling, grammar, and punctuation errors have been corrected. The name of the respondent, including the municipal enterprise, is mentioned in this decision. The affected party is a public law entity, and the relevant names are clearly evident from several cited legal provisions. A meaningful and content-preserving pseudonymization of the name of the respondent in this decision to be published in accordance with § 23 para. 2 DSG was therefore not possible.]

B E S C H E I D D E C I S I O N

The Data Protection Authority decides based on the report of violations of the protection of personal data pursuant to Art. 33 GDPR of the City of Vienna – Wiener Gesundheitsverbund (WiGev) (Controller), represented by the Magistrate of the City of Vienna, dated November 11, 2022, as follows:

- The Controller is ordered to notify the affected person within a period of two weeks of the security breach that occurred on **. June 2022 and was brought to the attention of the Controller on November 3, 2022, specifically the publication of the electronic nursing record of the affected person in the context of a social media post by an employee of the Controller, in accordance with Art. 34 para. 1 and para. 2 GDPR.

Legal bases: Art. 4 No. 12 and No. 15, Art. 33 para. 1 and para. 4, Art. 34 para. 1, para. 2 and para. 4, Art. 51 para. 1, Art. 57 para. 1 lit. a and lit. v as well as Art. 58 para. 2 lit. e of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter: GDPR), OJ No. L 119 of May 4, 2016, p. 1; § 18 para. 1 of the Data Protection Act (DSG), BGBl. I No. 165/1999 as amended; § 71 para. 1, para. 2 and para. 2 of the Constitution of the Federal Capital Vienna (Vienna City Constitution, hereinafter: WStV), LGBl. No. 28/1968 as amended; § 1 para. 1, § 4 as well as § 7 para. 1 of the regulation of the municipal council establishing a statute for the enterprise "Wiener Gesundheitsverbund", OJ 2020/02.

B E G R Ü N D U N G

A. Submissions of the parties and procedural history

1. In a submission dated November 11, 2022, the Controller, represented by the department responsible for data protection of the Magistrate of the City of Vienna, made the following submission: The report in question pursuant to Art. 33 GDPR was made merely "as a precaution," as it was not initially clear whether the matter at hand actually fell under its data protection responsibility. Given the case law of the Federal Administrative Court, the independent responsibility of the acting person was also possible. Furthermore, a risk could not currently be completely ruled out.

The Controller received an anonymous email on November 3, 2022, regarding the publication of three photos on the social network "****media." The internal reporting channels for handling "Data Breaches" did not function properly, which is why the responsible department and representative in the present procedure were only informed of the incident on November 10, 2022. According to the content of the email, a student had taken photos during her nursing internships with the Controller and posted them on ***media. Of these photos, only one taken in June 2022 could be attributed to the Controller. The other photos were taken at the sole responsibility of the acting person and were also reportedly covered by consent. The relevant photo was taken during the student's internship from **. May 2022 to **. July 2022 at the clinic **** and was partially redacted before publication on ***media. The photo shows the "electronic nursing record" of a patient at the mentioned clinic. While some areas were redacted, the following personal data remained visible: name, first name, patient number, ward, date, and information about nursing activities (details of care such as "inserting a venous catheter"). Additionally, user identifiers of three employees of the clinic and their area of work (acute geriatrics) were visible. It was only after the post was published (shared) that it was noticed that the redaction was not complete. The affected personal data – excerpts from the electronic nursing record – are to be classified as health data. Regarding the affected patient, a risk to rights and freedoms cannot be

completely ruled out, as the publication of the image resulted in a loss of control. Possible risks include identity theft, phishing, data sale, publication or public exposure, financial losses, economic or social disadvantages. A conversation was held with the student by the supervising authority. The student emphasized that it was important for her to point out,

that the photos were posted to positively portray experiences and activities within the nursing profession and that she deeply regrets the incident. Corresponding employment law measures have already been taken, particularly a reminder of the obligations under the GDPR. Based on an internal risk analysis, no high risk to the personal rights and freedoms of natural persons can currently be identified. Therefore, a communication in accordance with Art. 34 GDPR is not currently planned.

2. In response to corresponding requests for additional statements from the data protection authority, the responsible party submitted follow-up reports on November 14, 2022, December 21, 2022, December 22, 2022, and finally on January 18, 2023.

3. In the follow-up reports, the responsible party summarized as follows: It can be assumed that the publication of the photo on ***media occurred on **. June 2022 and that the post ("posting") was only online for three hours before being manually deleted by the student. It should also be noted that the responsible party, due to a lack of its own responsibility for posting on ***media, relied on the information provided by the student. Within the three hours, approximately 100 people viewed the post in the "Story." The stated number of 100 people corresponds to an average concerning the ***media stories of the student. She has 630 followers (confirmed subscribers) and the ***media profile is set to "private." Only these individuals would thus have had any (theoretical) access to the ***media stories. At the time of the report to the data protection authority, it was unclear whether the element of unauthorized disclosure as per Art. 4 No. 12 GDPR had been fulfilled concerning the student, who had independently taken the photo and then published it on ***media. The student was fundamentally authorized to access the electronic course for professional purposes. If the access was for such a permissible purpose, the disclosure to the student would not have been unauthorized. However, in the absence of corresponding evidence, unauthorized disclosure is now assumed in case of doubt. With the exception of the first and last name of the patient, no further personal data suitable for direct identification, such as date of birth, social security number, or address, are visible. In this regard, the responsible party believes it is very unlikely to establish a connection to a specific person. Furthermore, the designation of the ward "Acute Geriatrics" does not allow any conclusions to be drawn about the specific age and health status of the patient. Acute geriatrics merely indicates that intensive care is required. The indication of the nursing activity "insertion of a venous catheter" does not provide any information about the patient's overall health condition. Therefore, no further information about the patient's health status can be derived from the electronic course. The excerpt from the document...

****A. Risk Assessment****

The identifiable user abbreviations of the employees can only be resolved by authorized employees of the responsible party. In the risk assessment, the duration of publication was also taken into account. Due to the demonstrated lack of identifiability of the patient (and the three employees) and the limited duration of publication as well as the restricted group of individuals who had access to the post, the risk of impairment of the rights and freedoms of the affected persons is assessed as low. The probability of physical, material, or immaterial damage such as identity theft or fraud, financial loss, reputational damage, violation of the confidentiality of a professional secret, or other significant social or economic disadvantages is also assessed as low, and therefore, no notification of the affected person is required.

****B. Subject of Complaint****

The issue to be clarified is whether, in the procedure according to Art. 33 GDPR, taking into account the probability that the violation of the protection of personal data is likely to lead to a high risk according to Art. 34 GDPR, the data protection authority of the responsible party must be instructed to carry out the notification of the affected persons retroactively.

****C. Findings of Facts****

1. The Vienna Health Association is an enterprise of the City of Vienna, whose statute was issued by

the regulation of the municipal council of the City of Vienna GZ: V001/285/2020. The Vienna Health Association operates as a healthcare provider, among other things, eight hospitals (clinics), within which a variety of medical and health-related services are provided.

2. An employee (intern) in a training relationship with the responsible party, who was working at one of the clinics mentioned in point C.1 (specifically: “Clinic ****”) at the relevant time, queried electronically available data of a patient (affected person) of the responsible party as part of her duties and subsequently published a photograph of the electronically documented course of illness of the same (“electronic course”) on her social media profile on the platform “***media” of the operator N*** Ltd in June 2022. This was a post in the form of a “***media Story,” which, according to the default setting, is automatically deleted 24 hours after its publication. The post was visible for about three hours and was subsequently deleted by the employee herself. The employee's social media posts are viewed by an average of around 100 people.

3. The mentioned photograph contained the following information about the patient (affected person): first and last name, patient number, ward (specifically “Acute Geriatrics”), as well as information regarding nursing activities concerning her (specifically “insertion of a venous catheter”). Furthermore, it included the name abbreviations and work areas of three employees of the responsible party.

4. There was no consent regarding the publication of the information mentioned in point C.3 by the affected person at any time.

5. The responsible party was made aware of the publication mentioned in point C.2 on November 3, 2022, through an anonymous tip; however, this was only forwarded to the internally responsible department on November 10, 2022, which is why the initial report to the data protection authority was submitted on November 11, 2022. Specifically, this was done by the department responsible for data protection of the municipal authority of the City of Vienna. Subsequently, several supplementary reports and statements were submitted by the responsible party.

6. Until the conclusion of the present procedure, there was no notification and information provided to the affected person regarding the publication mentioned in point C.2.

****Assessment of Evidence:**** The findings made are primarily based on the consistent and thus entirely credible statements of the responsible party, represented by the competent department of the Vienna municipal authority, in the initial report of November 11, 2022, as well as the follow-up reports. The findings regarding points C.1 and C.2 are also based on an official query of the websites of the Vienna Health Association at www.gesundheitsverbund.at as well as the terms of use of ***media at www.***media.org, both queried on January 20, 2023.

****D. Legal Considerations****

D.1. General and Legal Basis

According to Art. 33 para. 1 GDPR, the responsible party must report a violation of the protection of personal data immediately and, if possible, within 72 hours after becoming aware of the violation to the competent supervisory authority. If the report to the supervisory authority is not made within 72 hours, a justification for the delay must be provided. If and to the extent that the information cannot be provided at the same time, the responsible party may provide this information gradually without undue further delay (para. 4 leg. cit.).

According to Art. 4 No. 12 GDPR, a “violation of the protection of personal data” is defined as a breach of security that, whether intentional or unlawful, leads to the destruction,

Loss, alteration, or unauthorized disclosure of or unauthorized access to personal data that has been transmitted, stored, or otherwise processed. In Recital 85 of the GDPR, potential consequences of a breach of personal data protection—if not responded to in a timely and appropriate manner—include, among others, physical, material, or immaterial damage due to loss of control over personal data, discrimination, identity theft, or loss of confidentiality of data subject to professional secrecy, or other significant economic or social disadvantages for the affected natural person. For these reasons, the controller should notify the supervisory authority immediately upon becoming aware of a breach of personal data protection. If the breach of personal data protection is likely to result in a high risk to the personal rights and freedoms of natural persons, the controller shall notify the affected person without delay of the breach in accordance with Article 34(1) of the GDPR. The notification to the affected

person shall describe, in clear and plain language, the nature of the breach of personal data protection and shall at least contain the information and measures referred to in Article 33(3)(b), (c), and (d) of the GDPR, as stated in paragraph 2 of the same article. According to Article 34(4) of the GDPR, if the controller has not already notified the affected person of the breach of personal data protection, the supervisory authority may require the controller to do so, taking into account the likelihood that the breach of personal data protection will result in a high risk, or it may determine by decision that certain conditions are met. The notification to the affected person is intended, according to Recital 86, to enable them to take the necessary precautions. Such notifications should always occur as quickly as possible at the discretion of the controller and in close consultation with the supervisory authority. Health data, according to Article 4(15) of the GDPR, are personal data related to the physical or mental health of a natural person, including the provision of health services, from which information about their health status can be derived. They are classified as special category data ("sensitive data") under Article 9(1) of the GDPR and processing them is associated with a certain (increased) risk, as stated in Recital 75 of the same article. According to Section 71(1) of the WStV, "enterprises" in the sense of this law are those economic entities to which the municipal council (of the City of Vienna) grants the status of an enterprise. The enterprises do not possess legal personality according to paragraph 2 of the same article. Their assets are managed separately from the other assets of the municipality. If an entry of the enterprises in the commercial register occurs, it must be evident from the designation that it is an enterprise of the City of Vienna. According to Section 71(3) of the WStV, the municipal council must adopt a statute for the enterprises by regulation, particularly taking into account the second paragraph of Section 67 of the same article. According to this, the director of the magistrate, who is directly subordinate to the mayor, is responsible for the management of the internal service of the magistrate and for the performance of the tasks reserved for him in the business allocation. According to the regulation of the municipal council, which issues a statute for the enterprise "Wiener Gesundheitsverbund," the enterprise "Wiener Gesundheitsverbund" is an economic entity to which the municipal council has granted the status of an enterprise (§ 1(1) of the same article). The municipal council has overall supervision over the enterprise "Wiener Gesundheitsverbund" (§ 4 of the same article). The mayor is subordinate to the director of the magistrate as well as all employees of the enterprise "Wiener Gesundheitsverbund" (§ 7(1) of the same article).

D.2. Regarding the occurrence of a security breach and related responsibility

It is explicitly stated in Article 33(1) of the GDPR, cited under point D.1., that the reporting obligation established therein is directed solely at the respective controller. Since the controller's responsibility has been repeatedly questioned during the proceedings, it is necessary to address this in more detail: Initially, it can be agreed with the controller to the extent that from (misused and extraneous) data inquiries, etc., by employees—especially for purely private purposes—an independent (possibly exclusive) data protection responsibility of the natural person can be derived in individual cases (see, for example, the decision of the DSB dated November 25, 2020, GZ: 2020-0.764.719).

However, while the relevant case law primarily relates to the responsibility asserted in the context of individual complaint procedures under Article 77(1) of the GDPR in conjunction with Section 24(1) of the DSG for violations of the rights of affected individuals (primarily under the law according to Section 1(1) of the DSG), the subject of the present proceedings is rather the—so to speak, preliminary—reporting and notification obligations of the (possibly merely original) controllers.

The purpose of these provisions (Articles 33 and 34 GDPR) is primarily the prevention and limitation of possible material and immaterial damages for affected individuals (see Martini in Paal/Pauly, General Data Protection Regulation (2017) Art. 33 para. 10-11). Furthermore, the EDPB Guidelines 07/2020 on the concepts of "controller" and "processor" state that even if an employee exceeds their authority in connection with the processing of data (unlawfully), the organization as the controller must nonetheless implement appropriate technical and organizational measures to ensure compliance with the GDPR (EDPB Guidelines 07/2020 on the concepts of controller and processor in the GDPR, adopted on July 7, 2021, para. 19).

The Federal Administrative Court also held in connection with the unauthorized use of data by an employee that the underlying organization (specifically: authority) remains responsible for the manner

of processing or use by its employees, even if it involves negligent use or excessive access to files. In this context, it was pointed out that a legal distinction must be made between the data protection-relevant behavior of the authority (as the original controller) and the data protection-relevant behavior of any third party. It was finally noted that under a contrary view, an organization could shift any data protection violations onto employees and thus evade its responsibility towards the individual seeking legal protection (see the ruling of the BVwG of January 20, 2022, GZ: W214 2239688-1).

Finally, the wording of Article 4(12) GDPR must be noted, according to which the term "breach of personal data protection" is to be understood in such a way that it also encompasses security breaches that are not influenced by the data processor or at least cannot be traced back to their culpable behavior (arg: "unintentional"), which lead to unauthorized disclosure or unauthorized access.

The corresponding EDPB Guidelines 9/2022 explicitly mention the "loss of control or access" by the (original) controller in relation to the term "breach" as defined in Article 33 GDPR (see EDPB Guidelines 9/2022 on personal data breach notification under GDPR, adopted on October 10, 2022, para. 19).

Overall, it can therefore be concluded in an interim result that an originally data protection-responsible party— even in the event of loss of control over or unauthorized access by third parties to its data—remains obligated under Articles 33 and 34 GDPR, and the related assertions of the controllers were therefore deemed irrelevant.

As can be inferred from the findings, the data in question concerning the affected person (patient) was collected in the context of medical treatment in a hospital operated by the "Vienna Health Association"—as an enterprise. This, in turn, is— as can be unequivocally derived from the provisions cited under point D.1 of the WStV and the corresponding regulation—assigned to the City of Vienna (see in particular the directive authority of the Mayor according to § 7 para. 1 of the regulation of the municipal council), which is represented in the present proceedings by the Magistrate of the City of Vienna (see the ruling of the BVwG of May 27, 2020, GZ: W214 2228346-1).

In this context, the Data Protection Authority concludes that for the data processed in the context of the hospital in question ("Clinic ****"), the City of Vienna qualifies as the data protection responsible party—and in the sense of the above statements—as the reporting and, if applicable, notification obligated party (for the latter, see point D.3.).

D.3. Regarding the notification obligation towards the affected person

The existence of a breach of personal data protection due to the unauthorized access to the data of the affected person (patient) and the subsequent unauthorized disclosure by the employee of the controller through her social media profile (see point C.2.) is beyond doubt and was, moreover, never questioned by the controller, who also submitted a report explicitly designated as such in accordance with Article 33 para. 1 GDPR.

A notification obligation towards the affected person under Article 34 para. 1 GDPR exists in those cases where it is likely—thus in the sense of a prognostic decision—that a high risk for the personal rights and freedoms of the affected persons is to be expected.

As the controller stated in its submission, the term "acute geriatrics" means that intensive (medical) care is required, and a specific medical treatment ("insertion of a venous catheter") was also evident.

In this context, it should initially be pointed out that the information concerning the affected person (patient) in question from the "electronic course" is, contrary to the assertions made in the subsequent submissions, both according to the broadly defined wording of Article 4(15) GDPR and according to the case law of the Data Protection Authority (see, for example, the decision of the DSB of November 19, 2020,

GZ: 2020-0.743.659) undoubtedly concerns health data ("health services") which, according to the intention of the legislator, are to be subject to increased protection (cf. Art. 9 para. 1 GDPR).

The Data Protection Authority has already stated that security breaches related to health data

generally pose a high risk (cf. Decision of the DSB dated August 8, 2018, GZ: DSB-D084.133/0002-DSB/2018).

Also, in the already cited Guidelines 9/2022 of the EDPB, it is expressly pointed out that, especially with health data, a high risk should regularly be assumed and that this can only be excluded in special exceptional cases (cf. Guidelines 9/2022 of the EDPB, para. 102 and 107 "nature, sensitivity, and volume of personal data"). Furthermore, it should be distinguished between a "mere" loss of medical data or the – subject matter of the proceedings – disclosure to unauthorized third parties, and in the latter case, an increased severity of the breach should be assumed (cf. Guidelines 9/2022 of the EDPB, para. 106 "type of breach"). It should also be noted whether the data – as in the case of the employees (cf. Point C.3.) – were disclosed in an encrypted form or similar, or – as in the case of the patient – were disclosed unencrypted and were directly identifiable due to name and address (cf. Guidelines 9/2022 of the EDPB, para. 111-112 "Ease of identification of individuals").

The Data Protection Authority does not overlook that the disclosure occurred for a limited period and to a restricted group of individuals. However, it should be noted that, based on general life experience, even a short period can lead to information – especially through its simple dissemination in the online context – being brought to the attention of a multitude of individuals, particularly those unknown to the responsible party (cf. Guidelines 9/2022 of the EDPB, para. 114, where the impossibility of assessing the intentions of unknown individuals poses an increased risk).

Finally, it should be noted that the responsible party did not mention any (potentially suitable technical or organizational) measures in the context of the present proceedings in the sense of Art. 34 para. 3 lit. a and b GDPR, and that the subsequent deletion of the social media post by the employee may not significantly reduce the potential high risk. There is also no disproportionate effort regarding the notification (lit. c leg. cit.).

As a result, it should be noted that the notification of the affected person (patient) is not only suitable pro futuro to avoid further violations of their personal rights and freedoms but is also – due to the identified risk potential – mandatory, and consequently, the responsible party was to be instructed to carry out the notification in accordance with Art. 58 para. 2 lit. e GDPR.

In terms of timing, the notification of affected individuals regarding the breach must generally occur without delay (cf. also Recital 86). In the specific case, a notification within a period of two weeks appears to be appropriate. Regarding the type and form, reference is made to Art. 34 para. 2 GDPR for the sake of completeness.

It was therefore to be decided accordingly.